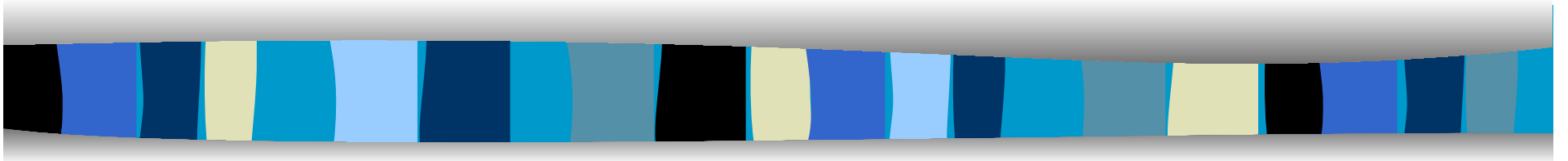


Public Key Distribution



PKI, PKIX, PGP, SSL, IPSec, Firewall

Public Key Distribution

- In public key cryptography, every user generate a pair of public key and private key.
- Private key is kept secret while public key is shared publicly.
- There are different methods to share the public key.
- Sharing public key does not require secure method but requires dependable method.

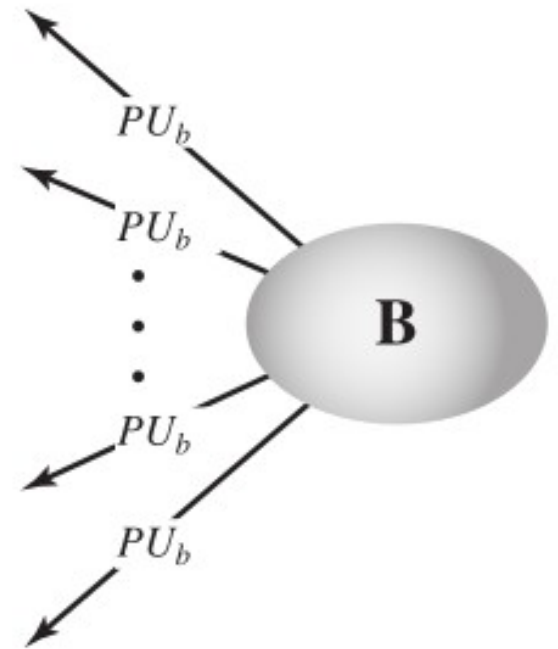
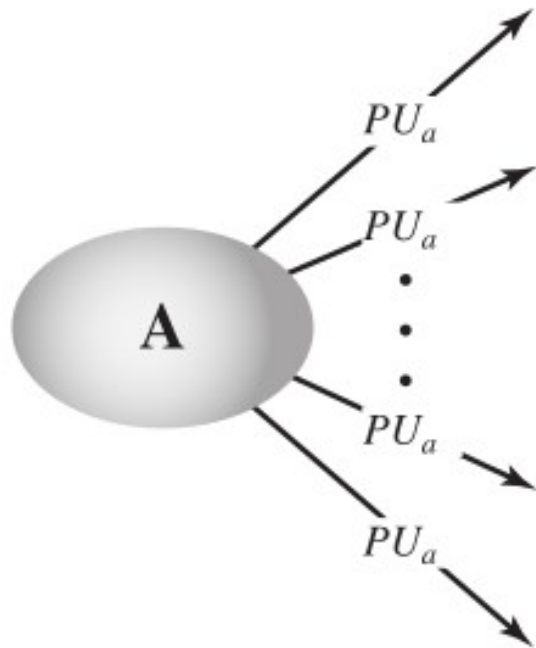
Methods to share Public Key

- Public Announcement
- Trusted Center
- Public Key Authority
- Certificate Authority

Public Announcement

- Public key can be shared on website, national newspaper or publicly announced.
- When Alice needs to send a confidential message to Bob, she can obtain Bob's public key from his site or from the newspaper, or even send a message to ask for it.
- Although this approach is convenient, it has a major weakness.

Public Announcement



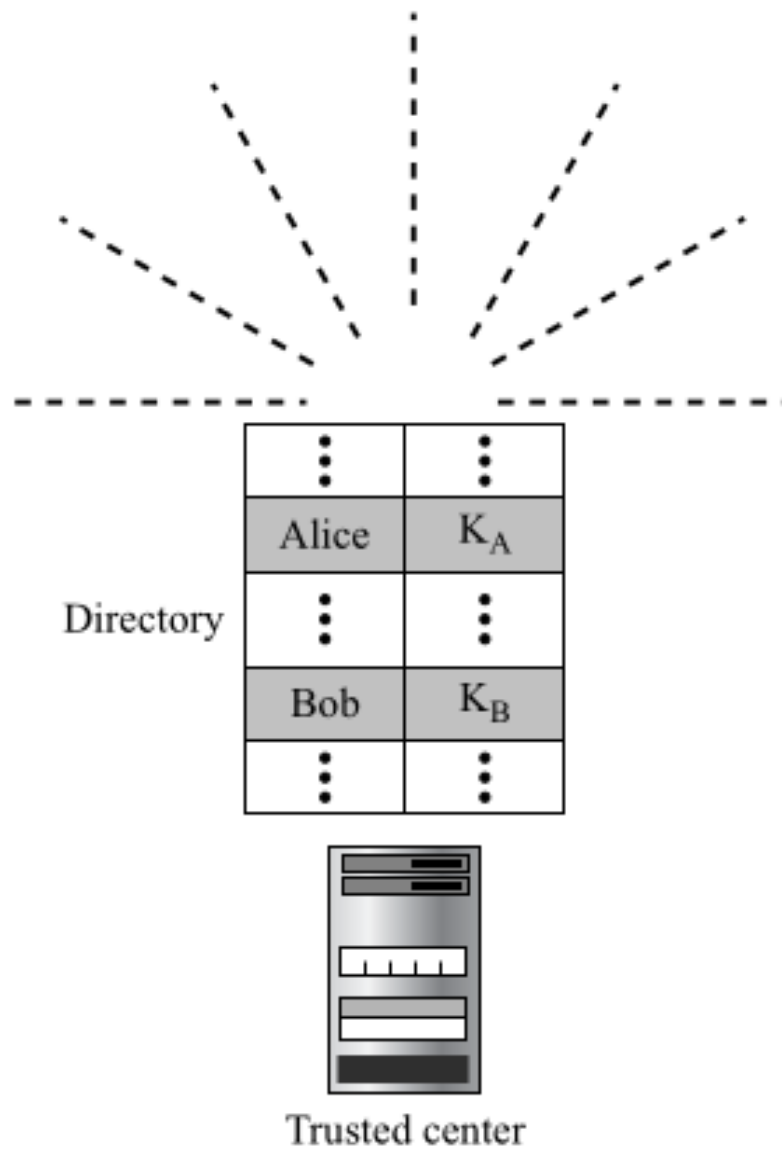
Trusted Center

- Public announcement is not trustworthy as the public key can be forged by anyone.
- That is, some user could pretend to be user A and send a public key to another participant or broadcast such a public key.
- The forger is then able to read all encrypted messages intended for A and can use the forged keys for authentication

Trusted Center

- A trusted center will maintain publicly available directory of public keys.
- Each participant registers his name and public key with trusted center in person or by some secure communication.
- Participant may request the TC to update the public key.
- Any participant who want to communicate can access the directory for public keys.

Trusted Center



Public Key Authority

- Public key authority is another trusted party that stores the user ids and their public key in a secret directory.
- The authority announces own public key only.
- If Alice need to communicate with Bob, then Alice request public key of Bob with authority.
- Request will contain timestamp of the message.
- Trusted center sends the public key of Bob encrypted with its own private key.

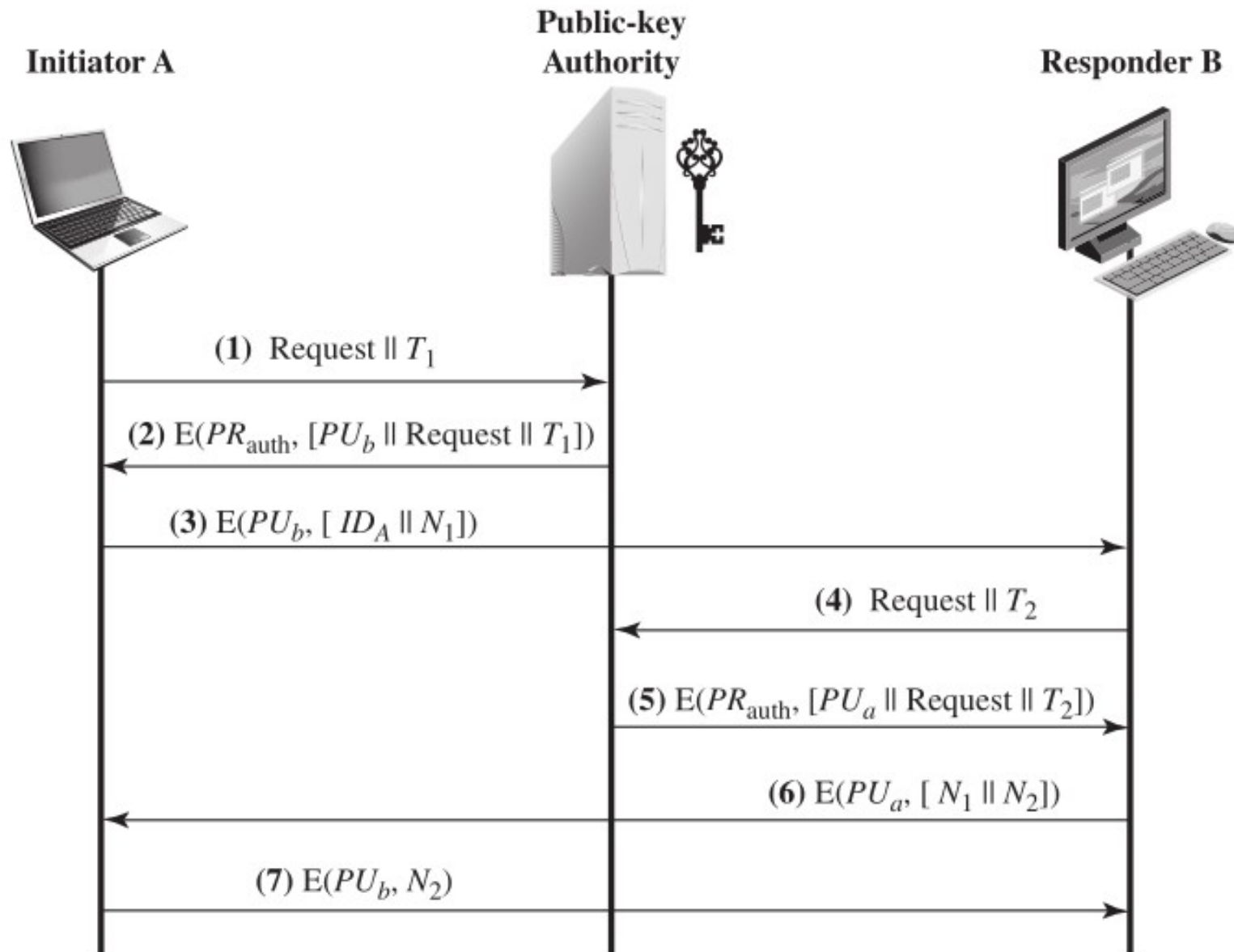
Public Key Authority

- Alice decrypts the message to get public key of Bob.
- Then Alice challenges Bob to decrypt the message with some nonce N_1 .
- Bob decrypts the message to get Nonce.
- Bob then request the public key of Alice with trusted center.
- Trusted center will send the public key of Alice in same way.

Public Key Authority

- Bob challenges Alice by sending some nonce for mutual authentication

Public Key Authority



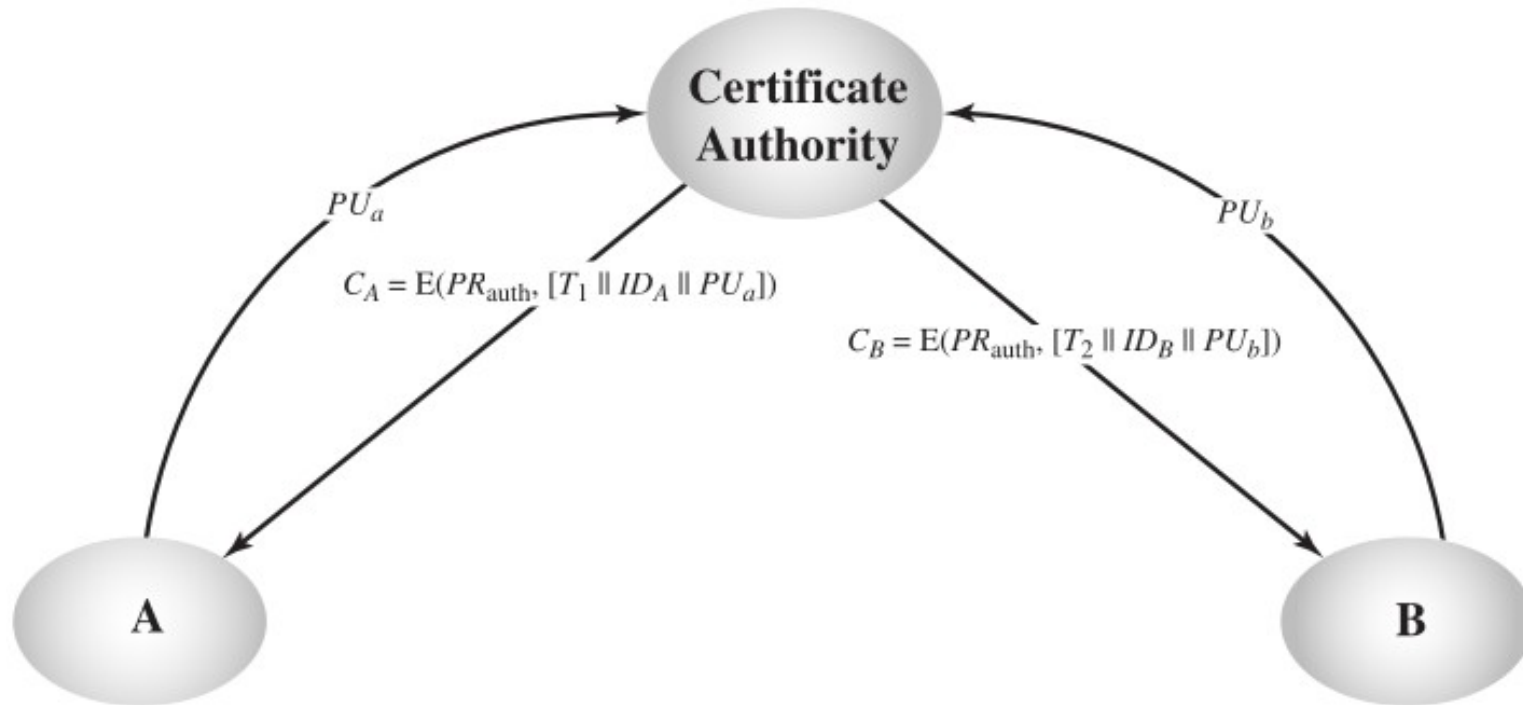
Certificate Authority

- In previous method, the public key authority will have huge bottleneck.
- So, we can have a certificate authority that can issue public key certificate to each users offline.
- The certificate consists of identity of owner, and its public key.
- Certificate is signed by certificate authority using its private key.

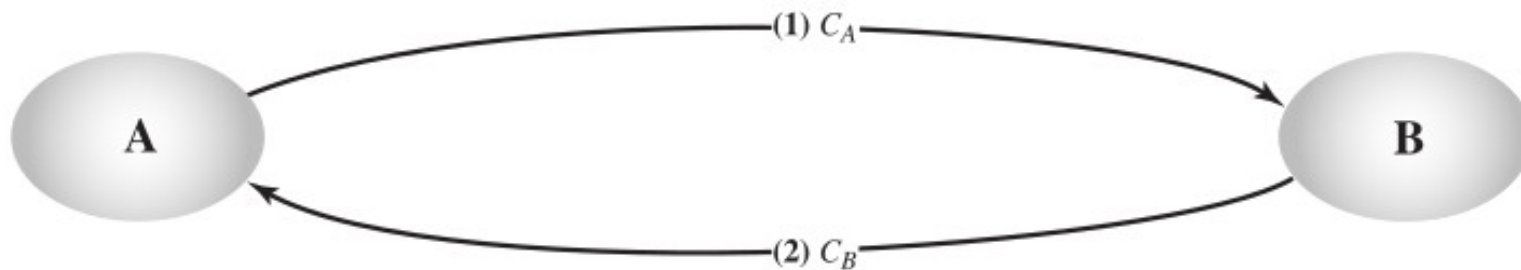
Certificate Authority

- To obtain the certificate, a user can present his or her public key to the authority in secure manner.
- The user can publish the certificate.
- User can also transmit its certificate to another user.
- Anyone can verify the certificate.

Certificate Authority



(a) Obtaining certificates from CA



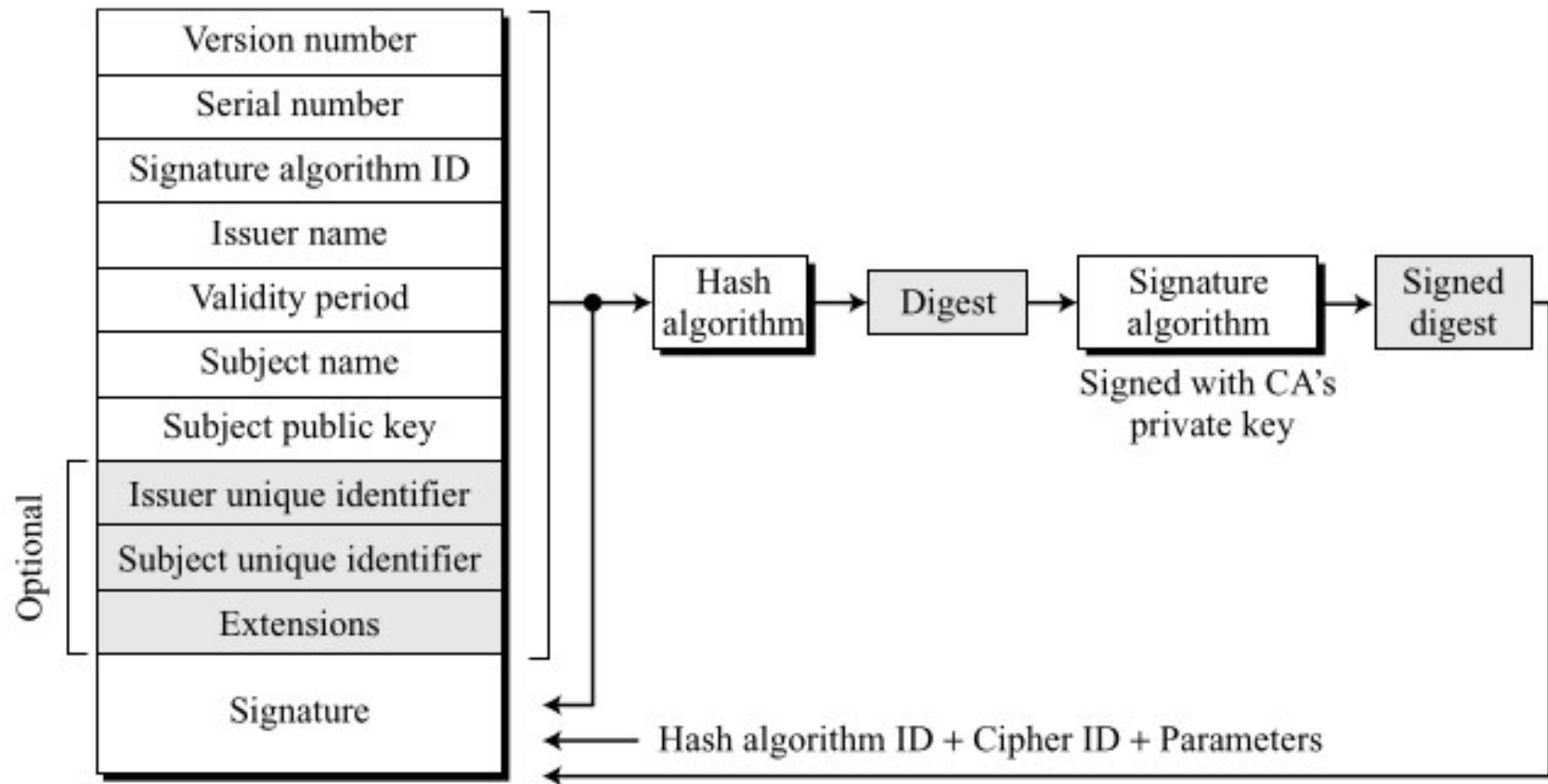
X.509 Certificate

- X.509 is a public key certificate standard recommended by ITU-T under X.500.
- This standard provides uniformity among digital certificates.
- Because anything that needs to be used universally must have a universal format.
- X.509 is based on public key cryptography such as RSA
- It was initially issued in 1988.

X.509 Certificate

- It was revised to address some sort of security concerns.
- Revised recommendation was issued in 1993.
- A third version was issued in 1995 and revised in 2000.

X.509 Certificate



Public Key Infrastructure PKI

- Public Key Infrastructure (PKI) is used to create and manage public key certificates.
- It creates digital certificates which bind public keys to entities, stores them securely and revokes them when required.
- It helps to confirm the identity of the entities involved in the communication.

Public Key Infrastructure PKI

- RFC 4949 (Internet Security Glossary) defines public-key infrastructure (PKI) as the set of hardware, software, people, policies, and procedures needed to create, manage, store, distribute, and revoke digital certificates based on asymmetric cryptography.

PKI Architecture

- **Single CA PKI**
- **Hierarchical PKI**

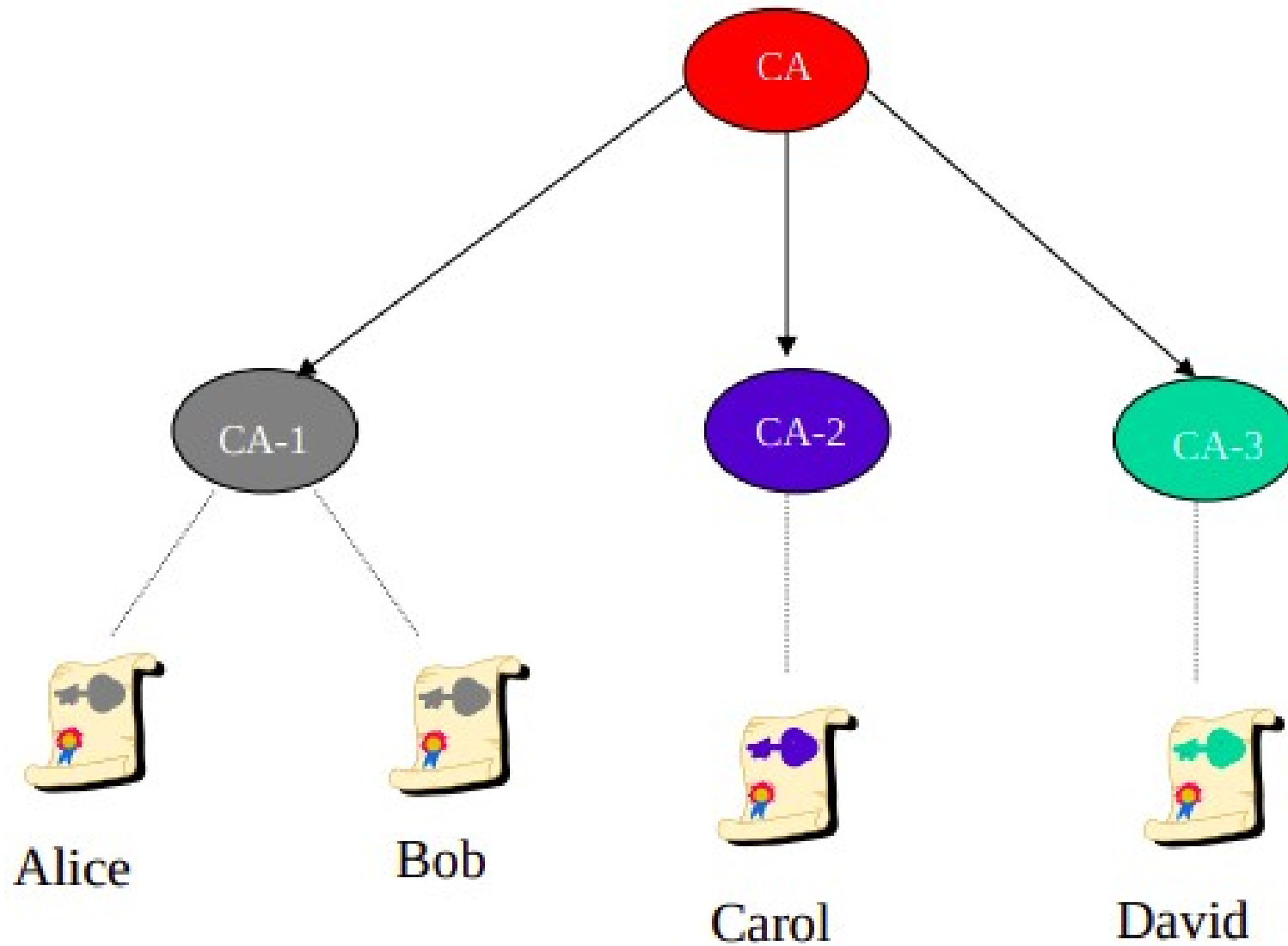
Single CA PKI

- A CA that issues certificates to users and systems, but not other CAs
- Easy to build
- Easy to maintain
- All users trust this CA
- But It is not possible to have just one CA issuing all certificates for all users in the world.

Hierarchical PKI

- In this model, there are multiple CAs.
- It has one top CA called root CA.
- Other CAs are subordinate of root CA.
- Root CA has a self-signed, self-issued certificate.
- Other CAs trust root CA

Hierarchical PKI



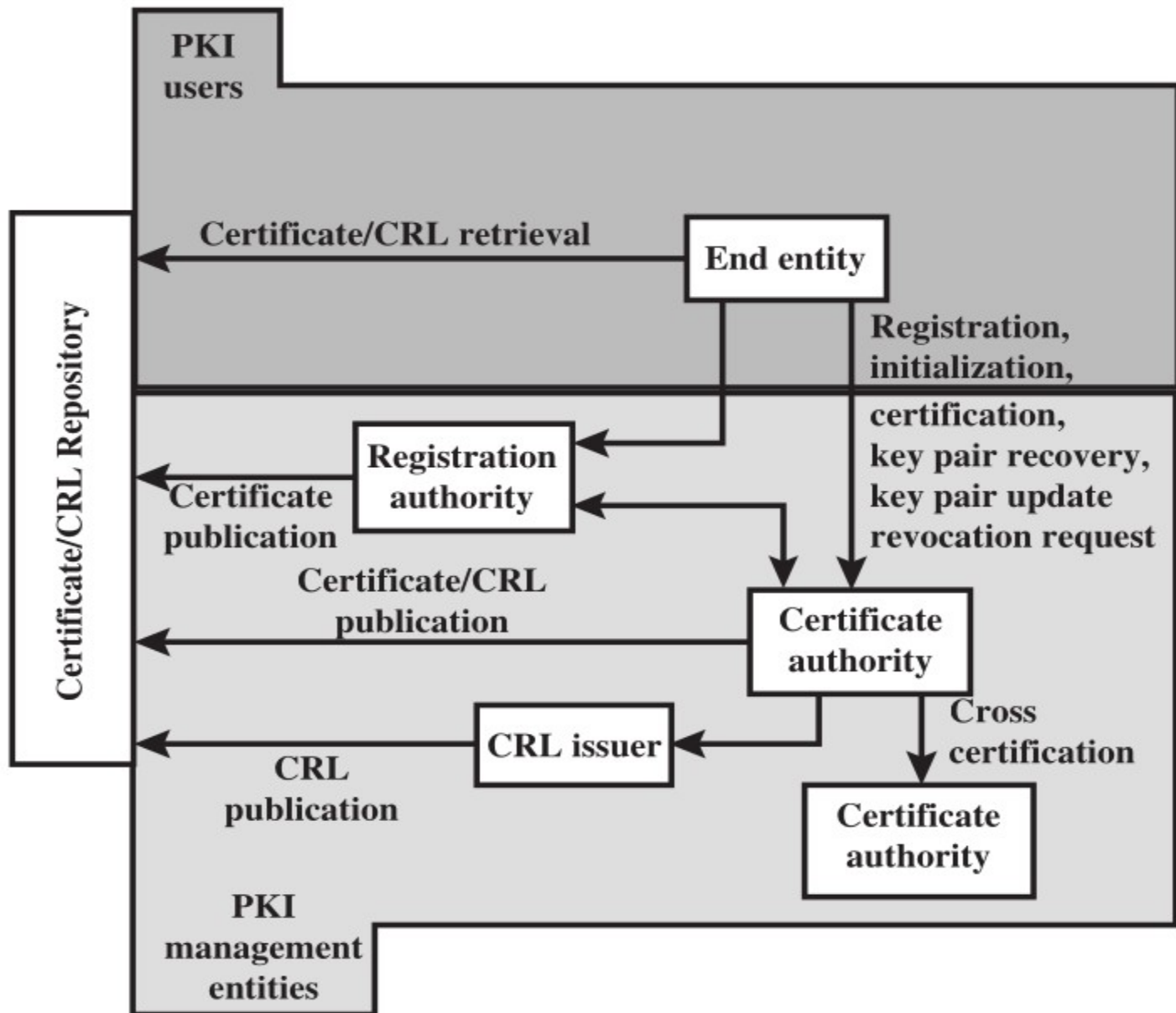
PKIX

- PKIX is a X.509 certificate based authentication technology deployed on the internet.
- It was proposed by the Internet Engineering Task Force (IETF).

Components of PKIX

- Certificate Authority
- Registration Authority
- Certificate Repositories
- CRL Issuers
- End Entity

Elements of PKIX



Components of PKIX

- **Certificate Authority**
- CA is a trusted third party that authenticates the identities of servers, individuals and other entities.
- A CA confirms the identity of the entity by issuing a digital certificates that binds the identity with the public key of that entity.
- It revokes and maintains the Certificate Revocation Lists (CRLs)
- Publish its certificates and CRLs
- Maintain status information of certificate expiration dates

Components of PKIX

- **Registration Authority**
- CA can delegate its function to Registration authority.
- RA validates the identity of the entity that places the request for digital certificate.
- RA verifies the identity of the owner by checking various identity documents such as drivers license or a pay stub etc.
- After verifying the identity, the RA then forwards the valid request to the CA.
- A CA can have more than one RA's.

Components of PKIX

- **Registration Authority**
- Each RA has a name and public key by which the CA can recognize it.
- Each RA is certified by its corresponding CA.
- Any message that the CA receives with the RA's signature is a trusted message

Components of PKIX

- **Certificate Repositories**
- Certificate repositories are mainly used to store and distribute certificates.
- All the issued certificates are stored in the repository so that the applications can retrieve them easily.

Components of PKIX

- **End entity**
- End entity can be end users, devices servers, routers), or any other entity that can be identified in the subject field of a public-key certificate.
- End entities typically consume and/or support PKI-related services.

Components of PKIX

- **CRL issuer**
- An optional component that a CA can delegate to publish CRLs.
- **Repository:** A generic term used to denote any method for storing distribute certificates and CRLs so that they can be retrieved by end entities.

PKIX management functions

- **Registration**
- This is the process whereby a user first makes itself known to a CA (directly or through an RA), prior to that CA issuing a certificate.
- Registration usually involves some offline or online procedure for mutual authentication.
- For registration, user has to provide its public key and other related information to CA or RA.

PKIX management functions

- **Initialization**
- Client needs to store the public key and other assured information of the trusted CA(s), to be used in validating certificate paths.
- **Certification**
- This is the process in which a CA issues a certificate for a user's public key, returns that certificate to the user's client system, and/or posts that certificate in a repository.

PKIX management functions

- **Key pair update:** All key pairs need to be updated regularly and new certificates issued.
- Update is required when the certificate lifetime expires and as a result of certificate revocation.
- **Revocation request:** An authorized person advises a CA of an abnormal situation requiring certificate revocation.
- Reasons for revocation include private key compromise, change in affiliation, and name change.

Cryptography Applications

- We have discussed different methods for secure communication.
- Some of these methods are symmetric cryptography, asymmetric cryptography, digital signature, cryptographic hash functions
- These methods helps us to achieve confidentiality, integrity and authentication which are very essential for secure communication.
- Now, we will study how these methods can be used in internet.

Cryptography Applications

- We need to provide security at different layers of protocol stack differently.
- This is because attacks can be made in each layer.
- If a laptop user connecting wirelessly to a wi-fi router wants to defend against sniffing on wireless channel, then its sufficient to secure the wireless link which is data link layer.
- Similarly for online payment, client has to connect with bank server
- So, transport layer security is needed.

Cryptography Applications

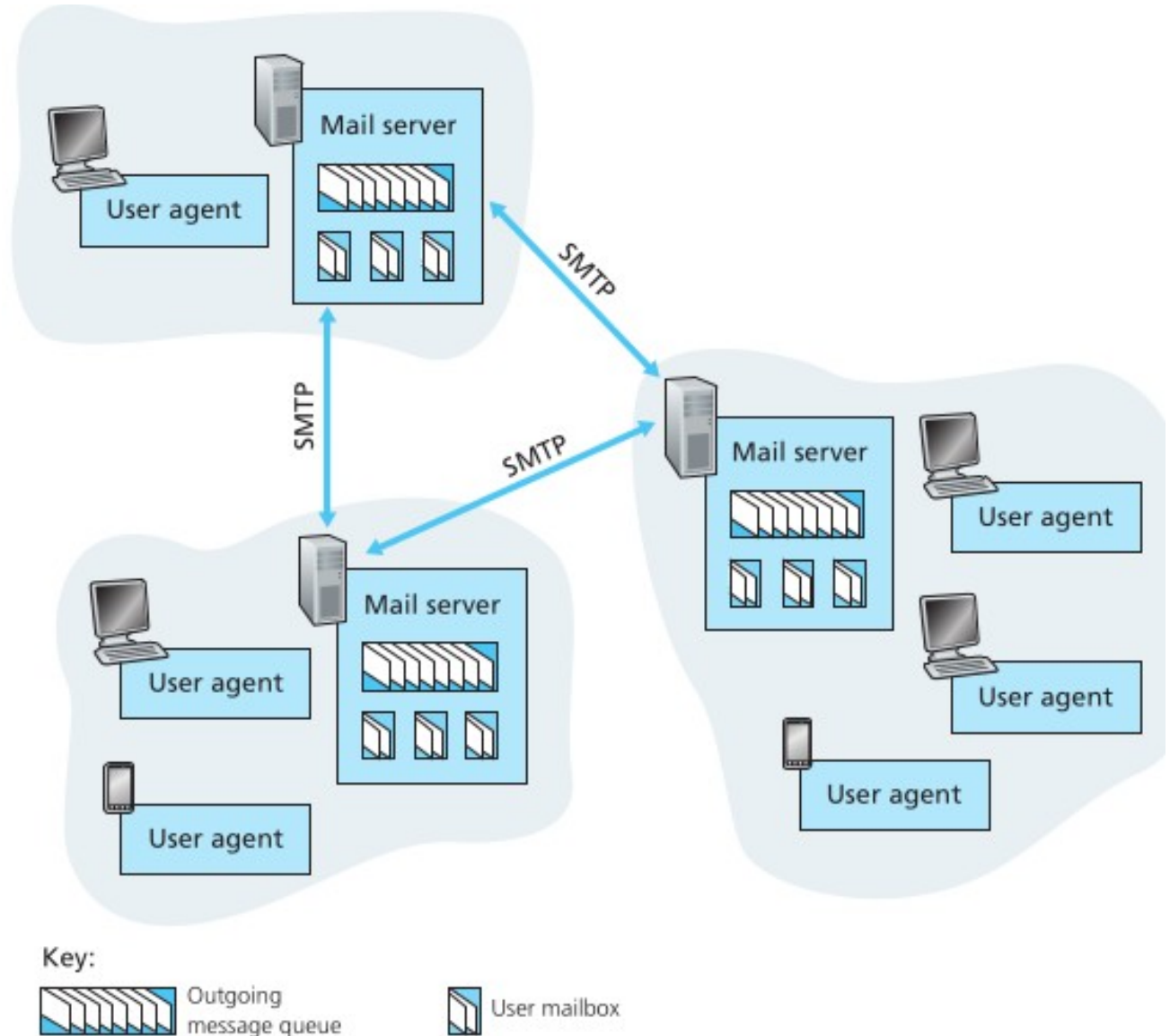
- A company may have different branches with different network.
- Attacker may analyze the traffic between two networks.
- To prevent this, we need network layer security.

Cryptography Applications

- We will see how we can use cryptography to secure
- Email security
- Transport layer security
- Internet layer security.

Components of Email

- User Agent
- Mail Servers
- SMTP



Components of Email

- **User Agent:** allows users to read, reply to, forward, compose emails.
- E.g. outlook, gmail, yahoo.

Components of Email

- **Mail Servers:** are core component of email infrastructure.
- Both message recipient and senders has its own mail servers.
- Each email recipient has a **mailbox** located in one of the mail servers.
- Mailbox manages and maintains messages that has been sent to him
- Each message sender has a **message queue** which is also stored in sender's mail server.

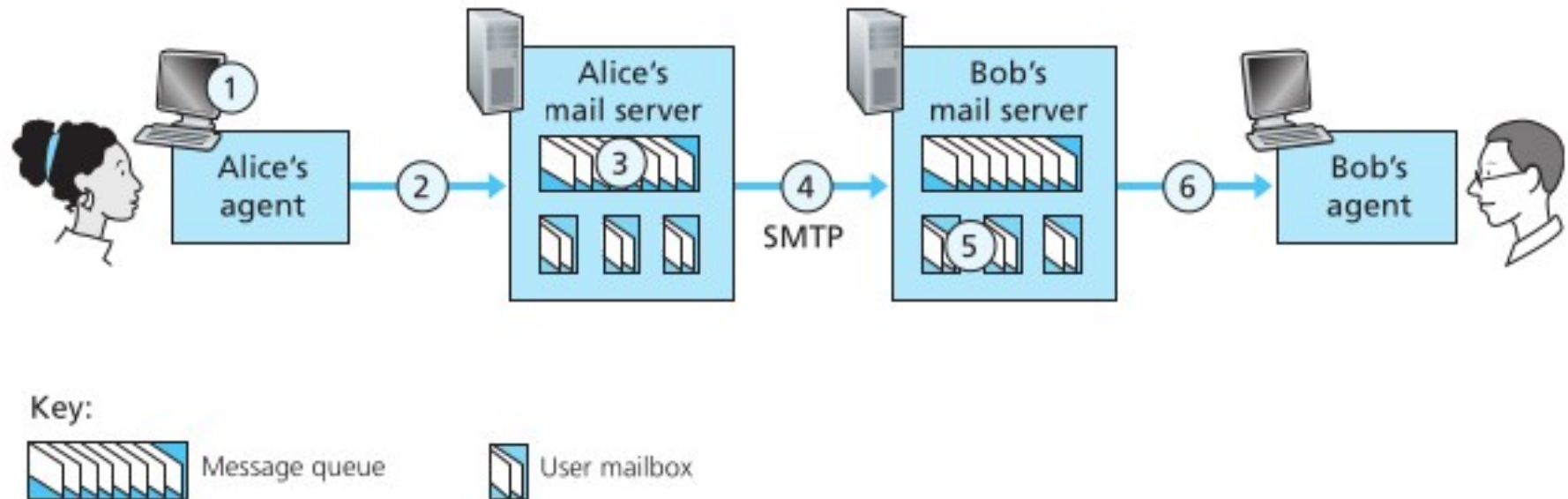
Email Overview

- **Mail Server:**
- Message queue holds the message that is failed to transfer to receiver's mail server.
- Mail server attempts to transfer the message in queue in every 30 minutes.

Email Overview

- **SMTP** is principal application layer protocol for email.
- It uses the reliable TCP to transfer mail from the sender's mail server to recipient's mail server.
- SMTP has two sides: a client side and a server side.
- Client SMTP executes at senders mail server
- Server SMTP executes at recipient's mail server.

Email Process



Email Process

- Alice invokes her user agent for e-mail, provides Bob's e-mail address, and composes a message, and instructs the user agent to send the message.
- Alice's user agent sends the message to her mail server, where it is placed in a message queue.
- The client side of SMTP, running on Alice's mail server, sees the message in the message queue.
- It opens a TCP connection to an SMTP server, running on Bob's mail server.

Email Process

- After some initial SMTP handshaking, the SMTP client sends Alice's message into the TCP connection.
- At Bob's mail server, the server side of SMTP receives the message.
- Bob's mail server then places the message in Bob's mailbox.
- Bob invokes his user agent to read the message at his convenience.

Email Security

- Sending an e-mail is a one-time activity.
- Email does not need session.
- Alice and Bob cannot create a session.
- Alice sends a message to Bob;
- Sometime later, Bob reads the message and may or may not send a reply.
- We discuss the security of a unidirectional message because what Alice sends to Bob is totally independent from what Bob sends to Alice.
- Pretty Good Privacy (PGP) was developed

Pretty Good Privacy

- PGP is email security package that ensures
- Confidentiality
- Message integrity
- Compression
- Key management
- It is free on internet for various platform including Windows, UNIX, Macintosh, and many more.
- PGP has grown explosively and is now widely used for number of reasons.

Pretty Good Privacy

- PGP is like a pre processor that takes plaintext as input and produces ciphertext as output.
- The output can then be emailed with user agent.
- Example of PGP message is

```
-----BEGIN PGP SIGNED MESSAGE-----
```

```
Hash:  SHA1
```

```
Bob:
```

```
Can I see you tonight?
```

```
Passionately yours, Alice
```

```
-----BEGIN PGP SIGNATURE-----
```

```
Version: PGP for Personal Privacy 5.0
```

```
Charset:  noconv
```

```
yhHJRHhGJGhg/12EpJ+lo8gE4vB3mqJhFEvZP9t6n7G6m5Gw2
```

```
-----END PGP SIGNATURE-----
```

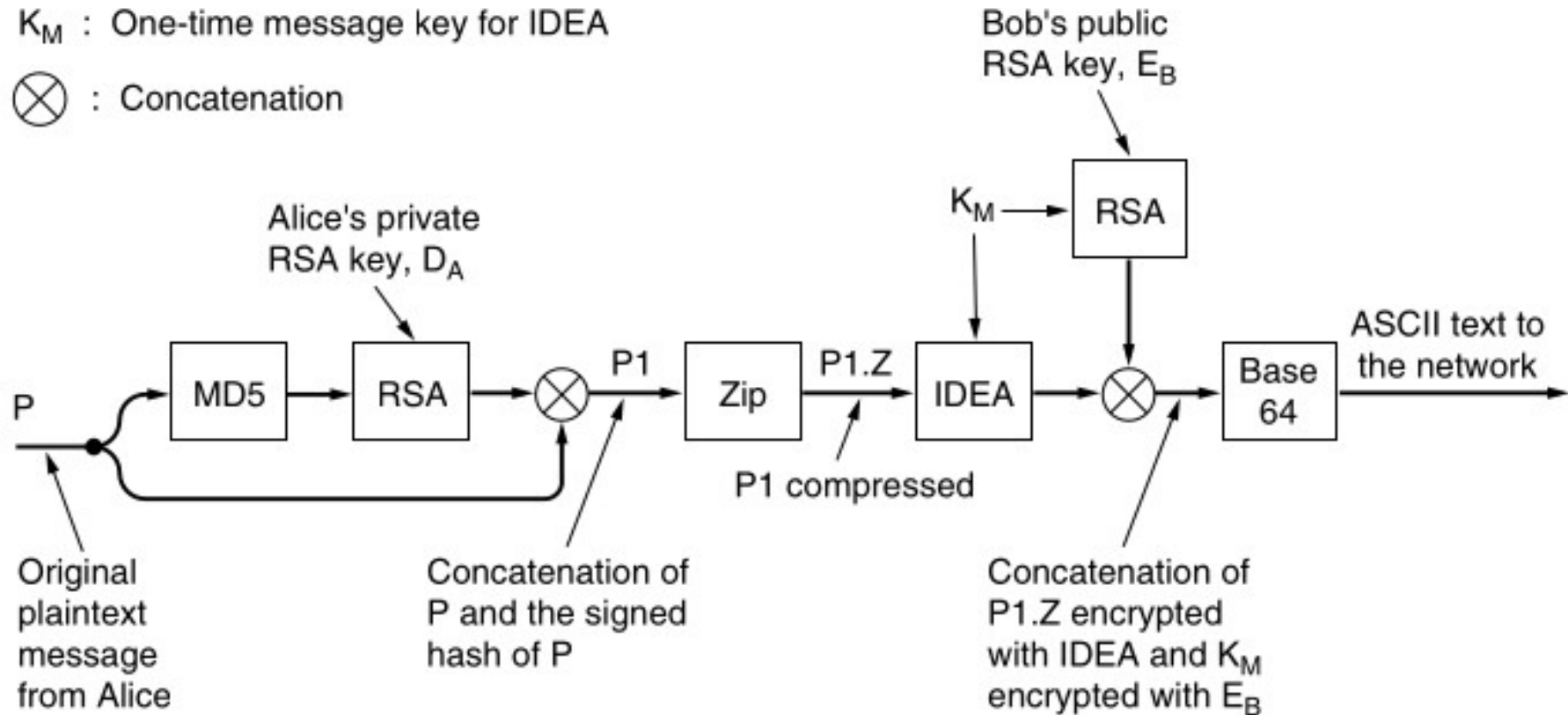
Pretty Good Privacy

- Its components are
- **IDEA** (Symmetric, 128 bit keys) encrypts email for confidentiality
- **Digital Signature** to sign SHA-1 or MD5 hashed message for message integrity.
- **Lempel-Ziv** for compression

PGP Operation

K_M : One-time message key for IDEA

$\otimes$: Concatenation



PGP Operation

- Suppose Alice wants to send email to Bob.
- PGP operates on email as follows.
 1. Alice composes email.
 2. PGP hashes the email with md5 to generate fixed size message digest.
 3. Alice signs the digest with its private key for integrity and authentication.
 4. The signature and message is appended for checking its integrity.

PGP

- 5. Then it is compressed with Lempel-ziv.
- 6. PGP generate random secrete key K_m to encrypt the compressed message with IDEA or 3DES.
- 7. So, secret key K_m is encrypted with RSA public key of Bob to share it with Bob
- 8. The encrypted key is appended with encrypted message.
- 9. For email compatibility, it is changed to ascii using base64.

Services Provided by PGP

- **E-mail compatibility**
- Encryption in PGP generates arbitrary stream of octets which are non printable.
- However, many electronic mail systems only permit the use of blocks consisting of ASCII text.
- PGP uses radix-64 to convert the raw 8-bit binary stream to a stream of printable ASCII characters.

Services Provided by PGP

- **E-mail compatibility**
- Suppose the email message is: new
- ASCII format: 01101110 01100101 01110111
- After encryption: 10010001 10011010 10001000
- The Radix-64 conversion:
- 24-bit block: 10010001 10011010 10001000
- 6-bit blocks: 100100 011001 101010 001000
- Integer version: 36 25 38 8
- Printable version: k Topic 1 Z m l

Security at Transport Layer

- Transport layer provides various services such as reliability, congestion control and flow control.
- But it does not support security services.
- Remember that transport layer security is very important for transactions on the Internet.

Need of Security at Transport Layer

- Suppose customer visits the website of Alice Incorporation to order some perfume.
- The Bob enters type of perfume, quantity, credit card information in a form and submit it.
- In this scenario, following attacks may occur.
- Turdy may sniff Bob's messages, get credit card information and use it to make purchases.
- Turdy may increase the number of quantities.
- Turdy may send fake website claiming to be Alice Incorporation.

Security at Transport Layer

- Two dominant protocols for providing security at the transport layer are:
- The Secure Sockets Layer (SSL) Protocol and
- The Transport Layer Security (TLS) Protocol.
- The TLS is standardized version of SSL.

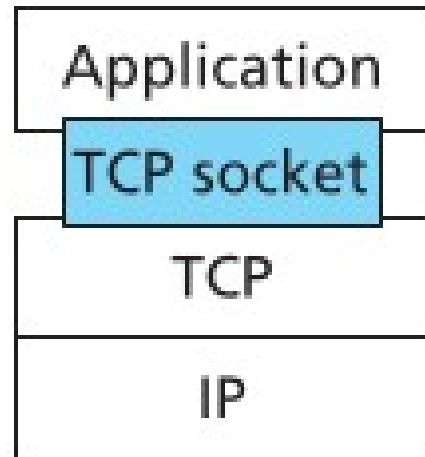
Secure Socket Layer

- SSL is extensively used in internet to secure web traffic.
- It is used by Google, Amazon, eBay etc
- It is useful when sensitive information needs to be transferred, e.g. credit card details in e-commerce transaction, passwords during login.
- When SSL is used by browsers, the URL begins with https instead of http
- SSL can be used to secure any application that uses TCP.

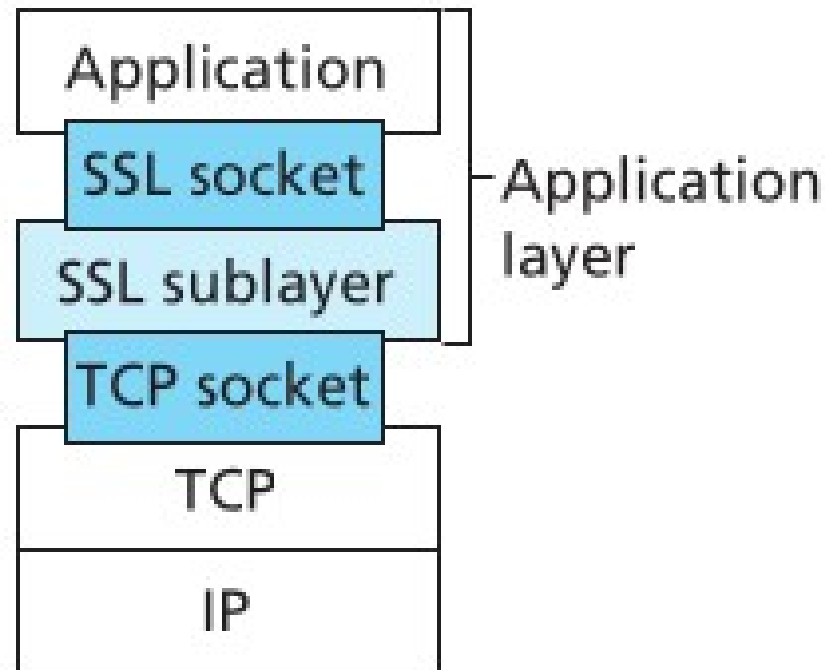
SSL Services

- Confidentiality
- Message Integrity
- Server Authentication
- Client Authentication

SSL



TCP API



TCP enhanced with SSL

Secure Socket Layer

- SSL is an additional sub-layer in protocol stack to maintain security at transport layer.
- When there is no SSL, the communication between application and TCP is through TCP socket.
- TCP socket is used by application in application layer to send to and receive the messages from TCP.
- So, socket is an API that provides the commands such as send the message, receive the message, open and close the connections.

Secure Socket Layer

- Similarly, we add SSL sub-layer between application and transport layer for security.
- Now, the communication between application and SSL sub-layer is through SSL socket.
- And SSL uses commands provided in TCP socket that helps to communicate with TCP.
- SSL provides different mechanism to provide confidentiality, integrity, authentication and so on.
- Application uses SSL socket commands to access the services provided by SSL layer.
- The commands can be send receive messages, open close connections in secure way.

Secure Socket Layer

- SSL has three phases
- 1. handshake
- 2. Key Derivation
- 3. Data Transfer

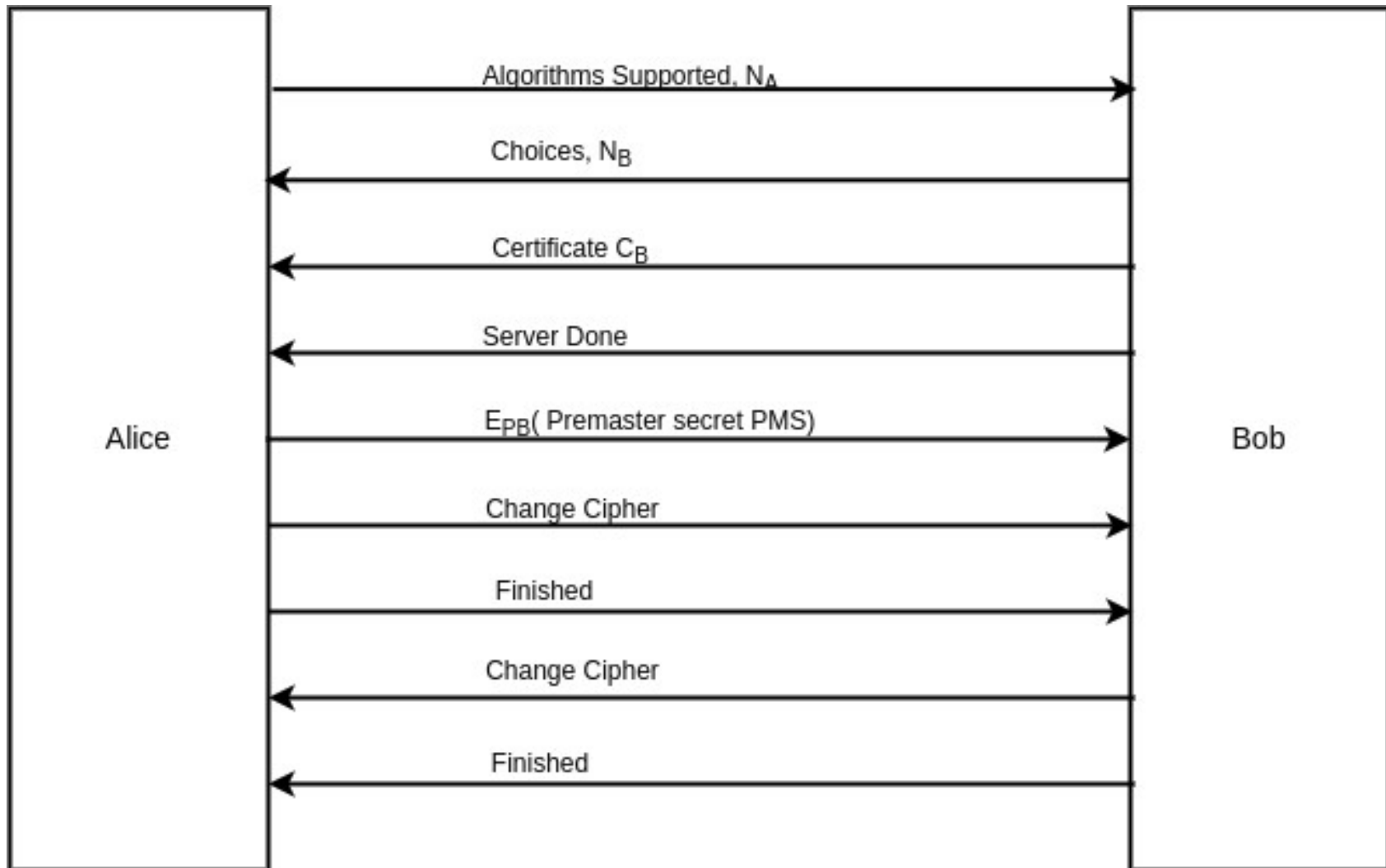
SSL: Handshake

- 1. The client sends a list of cryptographic algorithms it supports, along with a client nonce.
- 2. From the list, the server chooses a symmetric algorithm (for example, AES), a public key algorithm (for example, RSA with a specific key length), and a MAC algorithm.
- It sends back to the client its choices, as well as a certificate and a server nonce.
- 3. The client verifies the certificate, extracts the server's public key, generates a Pre-Master Secret (PMS), encrypts the PMS with the server's public key, and sends the encrypted PMS to the server.

SSL: Handshake

- 4. Using the same key derivation function (as specified by the SSL standard), the client and server independently compute the Master Secret (MS) from the PMS and nonces.
- The MS is then sliced up to generate the two encryption (E_A, E_B) and two MAC (M_A, M_B) keys.
- Henceforth, all messages sent between client and server are encrypted and authenticated (with the MAC).
- 5. The client sends a MAC of all the handshake messages.
- 6. The server sends a MAC of all the handshake messages.

SSL: Handshake and Key Derivation



SSL: Data Transfer

- Message is fragmented into blocks of 2^{14} bytes called **SSL Record**.
- Blocks are optionally compressed.
- MAC is computed using record data, MAC key, type, version, length, and a sequence number and appended to the block.
- Client and server maintains a sequence number starting from 0.
- Each time, a block is created, sequence number is incremented.

SSL: Data Transfer

- Sequence number secures the communication.
- Then it is encrypted using symmetric encryption key.
- Finally, header is prepend.
- The header consists of following fields
- **Content type (8 bits):** It specifies the type of the SSL record (handshake, data transfer, close)
- **Version (8 bits):** Indicates SSL version of SSL used.
- **Compressed length (16 bits):** The length in bytes of compressed fragment

SSL: Data Transfer

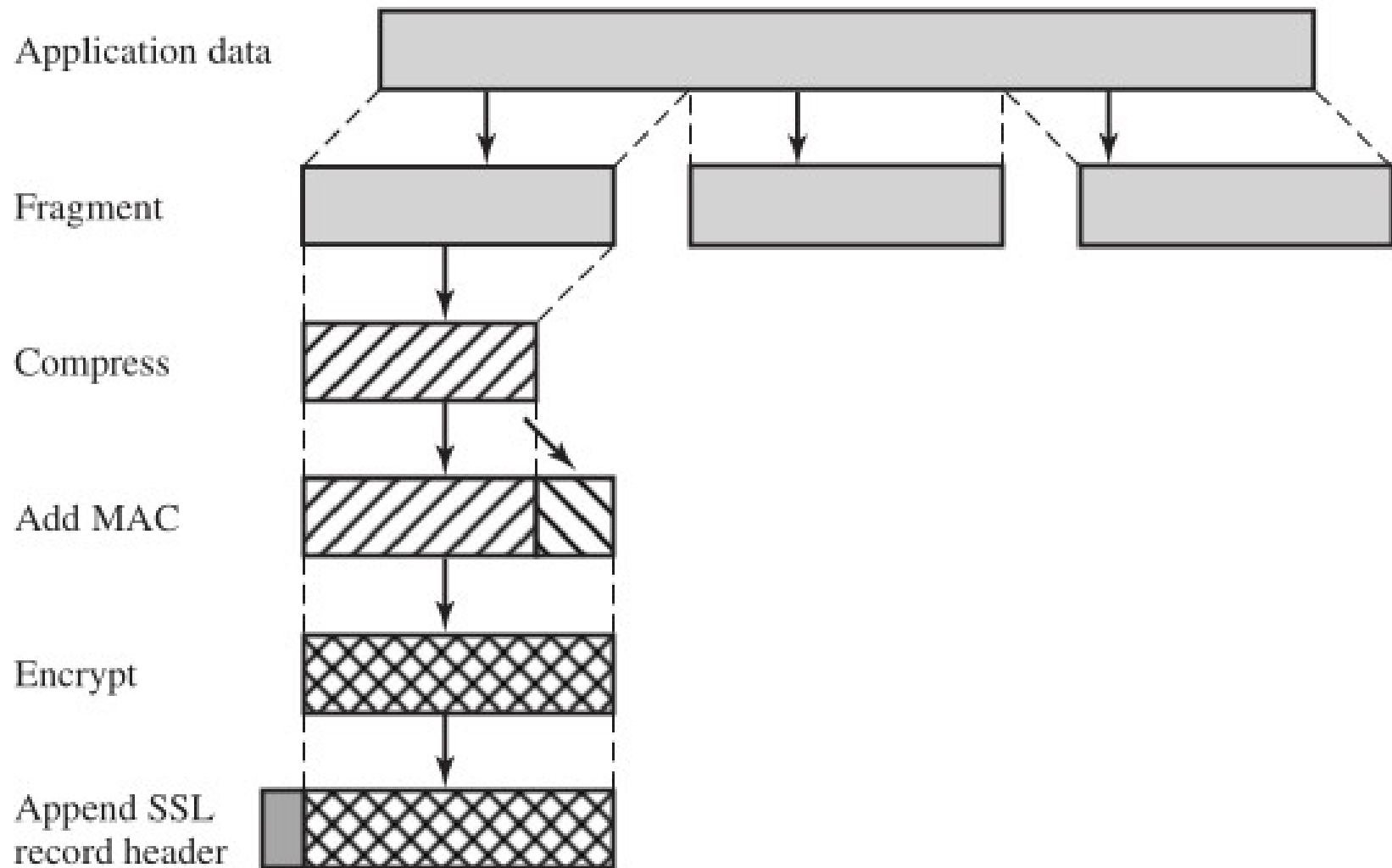


Figure 17.3 SSL Record Protocol Operation

Figure 17.3

SSL: Data Transfer

- **SSL Record**

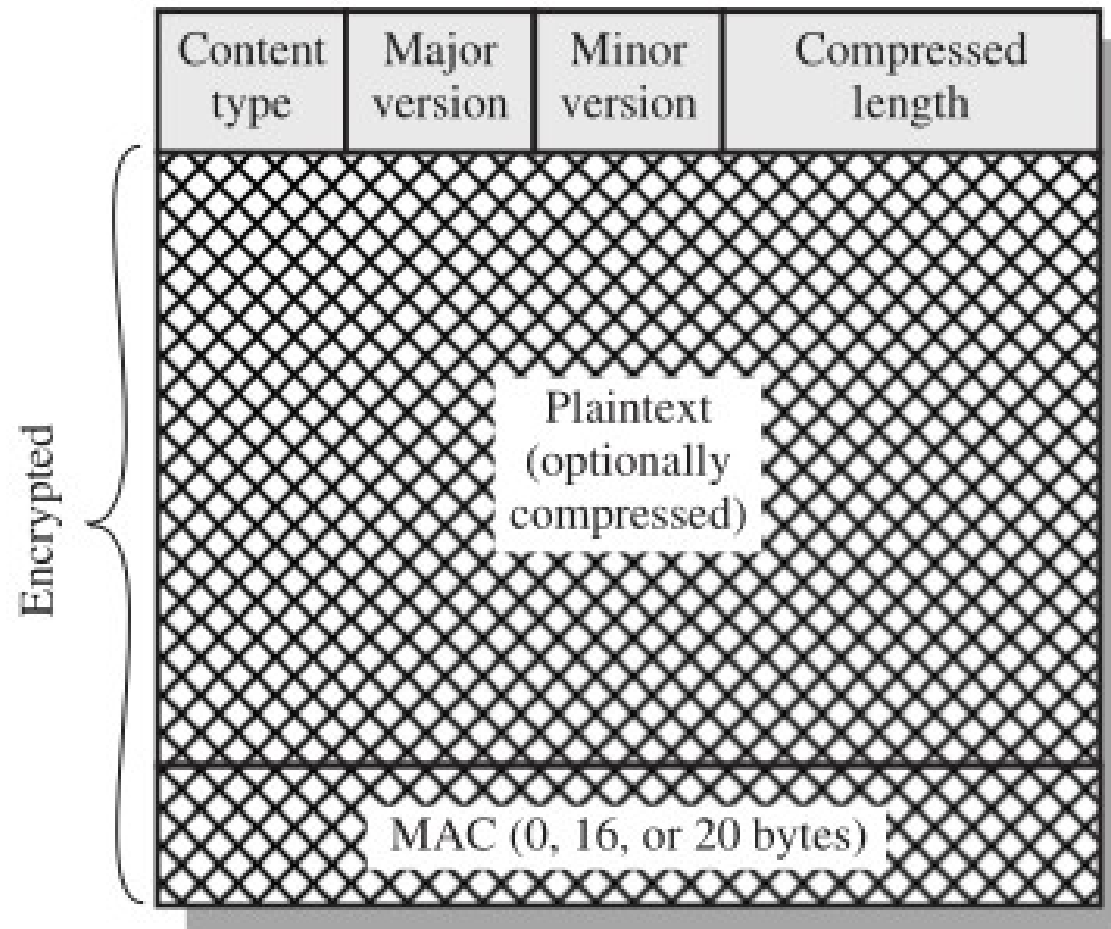


Figure 17.4 SSL Record Format

SSL: Connection Closure

- After data has been transmitted, SSL session has to be closed.
- One approach would be to end the SSL session by simply terminating the underlying TCP connection by sending TCP FIN segment.
- In such case, Trudy also can terminate SSL session in the middle of an ongoing SSL session with TCP FIN.
- So, the secure method is to indicate in the type field whether the record serves to terminate the SSL session.
- The record type can be authenticated with record MAC

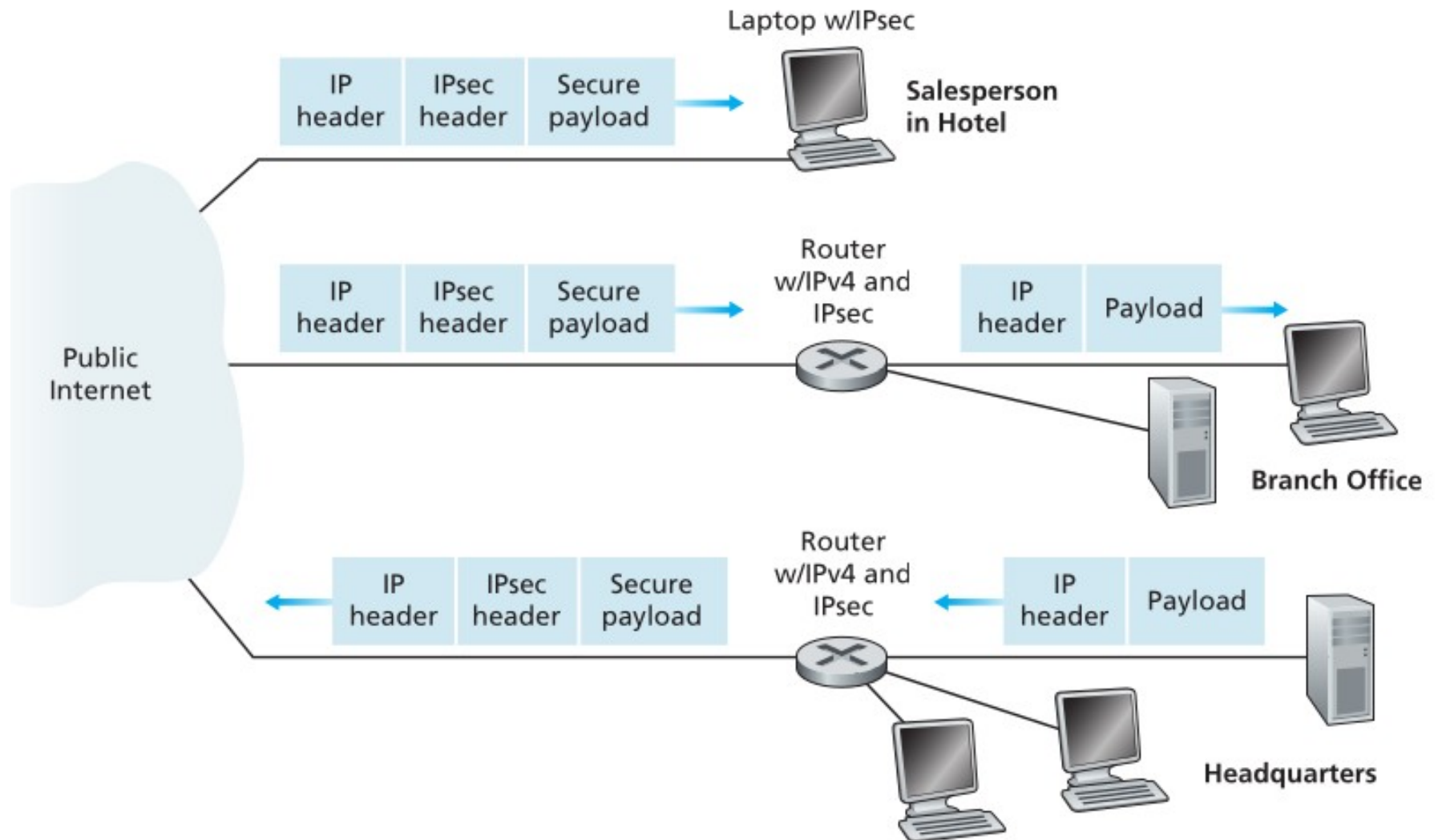
IP Security

- IPsec provides security at network layer.
- So, it is used to establish a secure connection between the network layer entities (hosts or router)
- IT provides following security services:
- **Confidentiality**: by encrypting the payload (transport layer header and application layer data)
- **End point Authentication**
- **Message Integrity** using MAC
- Detect Duplicate packets and reordering of packets

IPSec: Virtual Private Network

- IPSec uses virtual private network for Network layer security.
- In VPN, communication among different users located at different locations is carried out through public network as if they are in same private network.
- In VPN, a tunnel is created between two gateway routers of different offices.
- Then packet is routed through the tunnel from one node of a branch to another of different branch.

IPSec: Virtual Private Network



IPSec: Operation

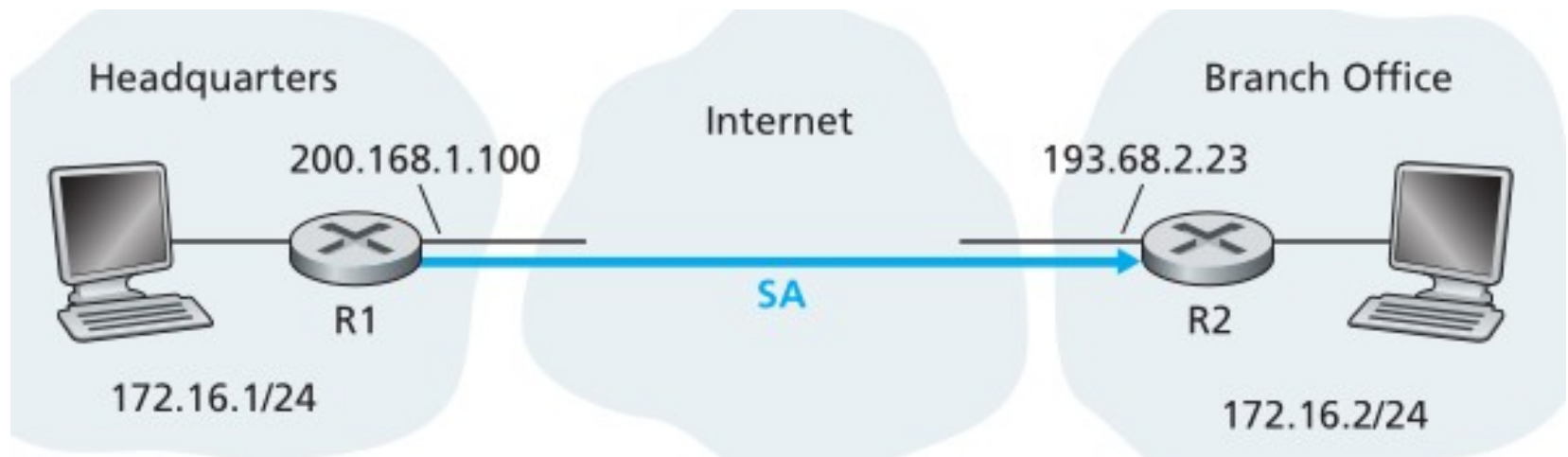
- Protocols used in IPSec
- **Internet Key Exchange**
- **Authentication Header or Encapsulating Security Payload**

IPSec: Internet Key Exchange

- IPSec creates a secure connection between two gateway routers R1 and node R2 called Security Association (SA) or tunnel.
- SA is the logical connection between the network layer nodes.
- SA is simplex.
- Suppose there is corporate bidirectional VPN between headquarter offices, branch office and n travelling sales persons.
- Total no. of SA required is $2n + n$

IPSec: Security Association

- Consider SA between router R1 and router R2.



- State information about SA is maintained by R1 and R2 in Security Association Database (SAD).
- SA is identified by three parameters.
- Security Parameter Index, Destination IP Address, Security Protocol Identifier.

IPSec: State information about SA

- A 32-bit identifier for the SA, called the Security Parameter Index (SPI)
- The origin interface (e.g. 200.168.1.100) and destination interface (e.g. 193.68.2.23)
- The algorithm to be used for encryption (e.g. 3DES)
- The encryption key
- The algorithm to be used for MAC computation (e.g. MD5).
- The authentication key.

IPSec: State information about SA

- Whenever R1 needs to construct Ipsec packet , it assess the state information of corresponding SA to find out how to encrypt packet and compute MAC.
- Same applies for decryption.

IPSec: Key Management

- To establish an SA, R1 and R2 must authenticate each other and agree on the encryption and message integrity algorithms and keys and SPI.
- This is done using IKE protocol.
- 1. Two entities exchange certificates containing their public keys.
- 2. Negotiate encryption and MAC computation algorithms.
- 3. Exchange the key material from which the encryption and authentication keys are derived.

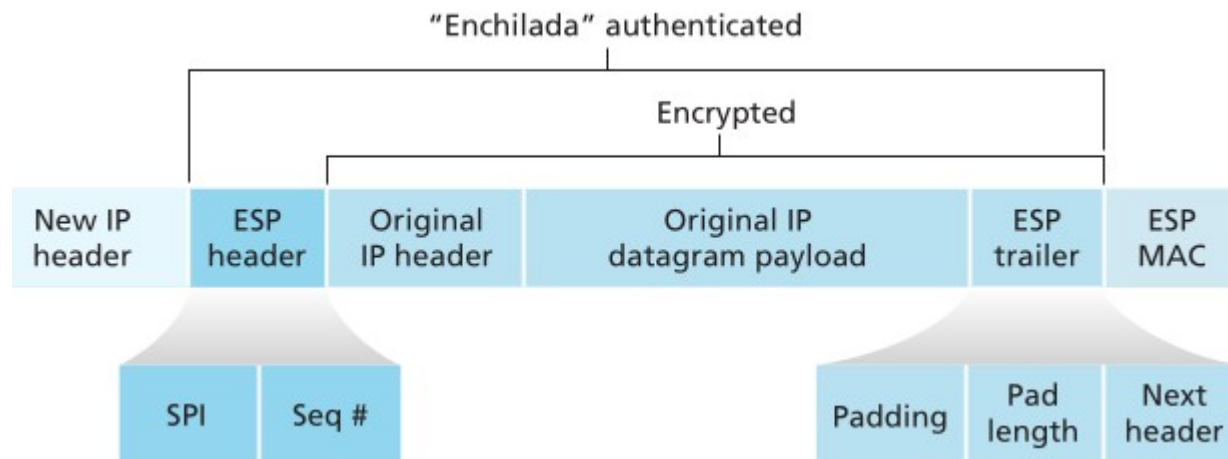
IPSec: Authentication Header

- After establishment of SA, data can be transferred securely through it.
- For this AH protocol can be used.
- AH is an extension header to provide only message authentication.
- So, use of AH is deprecated.
- We will not discuss AH instead we will study better solution ESP in detail.

IPSec: Encapsulating Security Payload

- ESP is an Ipsec protocol used to transfer the packets through SA.
- It provides confidentiality, message integrity, detection of deleted, duplicate or reordered packets.
- Confidentiality is provided using encryption.
- MAC is added to packet for message integrity.
- Sequence number is used to detect addition, deletion, duplicate or reordered packets.
- ESP adds a header containing SPI, sequence number, MAC and some other fields to packet

IPSec: ESP



IP Security Modes

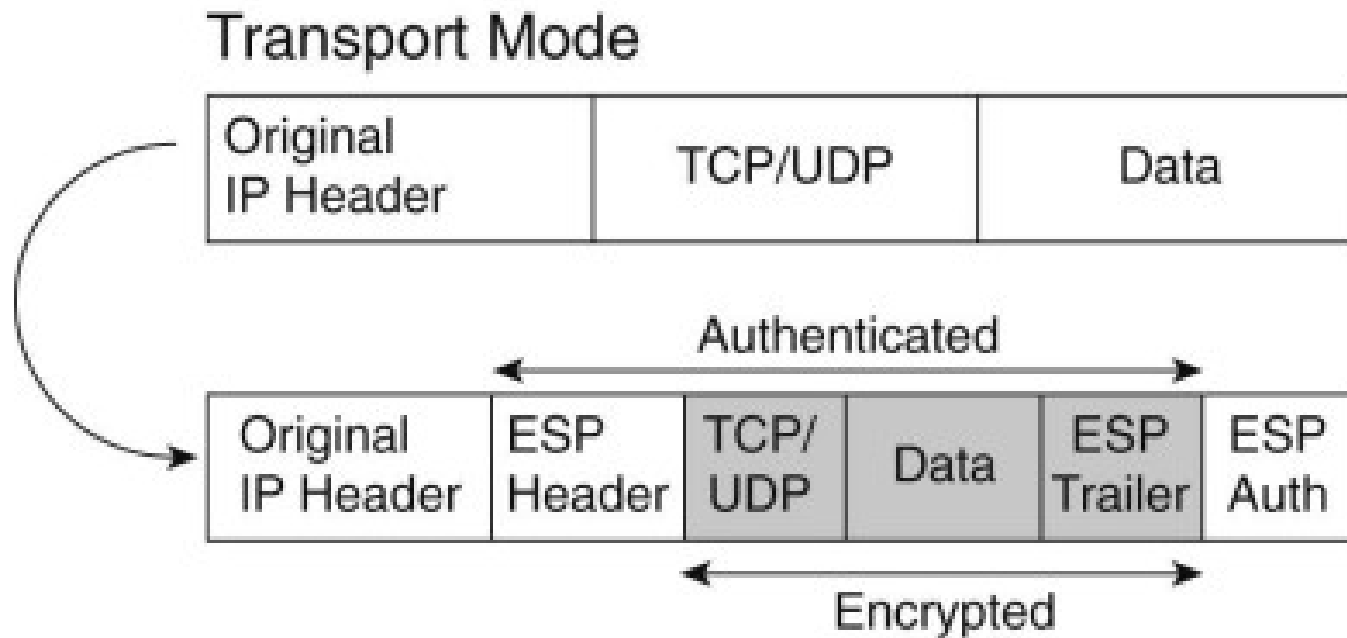
- ESP supports two modes of operations
- **Transport mode** and
- **Tunnel mode.**

IP Security Modes

- **Transport Mode**
- Original IP header is not changed and not encrypted.
- Transport mode is efficient as no extra header.
- Designed for host to host communication.

IP Security Modes

- **Transport Mode**



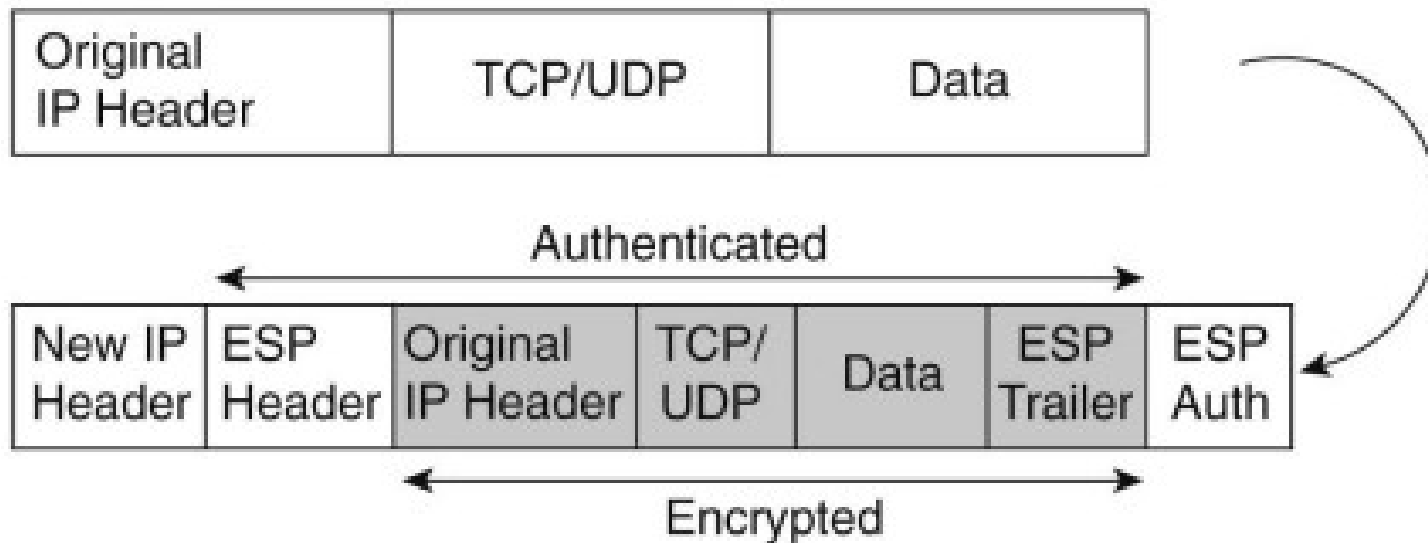
IP Security Modes

- **Tunnel Mode**
- Original IP header is encrypted and not visible to attackers.
- New IP header is added.
- The source and destination IP address in new IP header and original IP header are different.
- Designed for router to router or router to host communication.

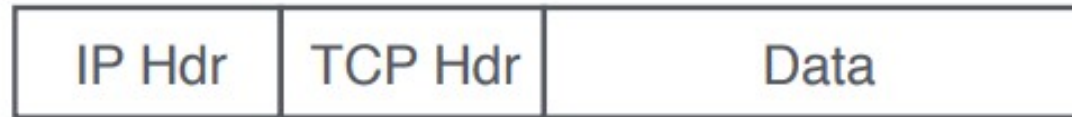
IP Security Modes

- **Tunnel Mode**

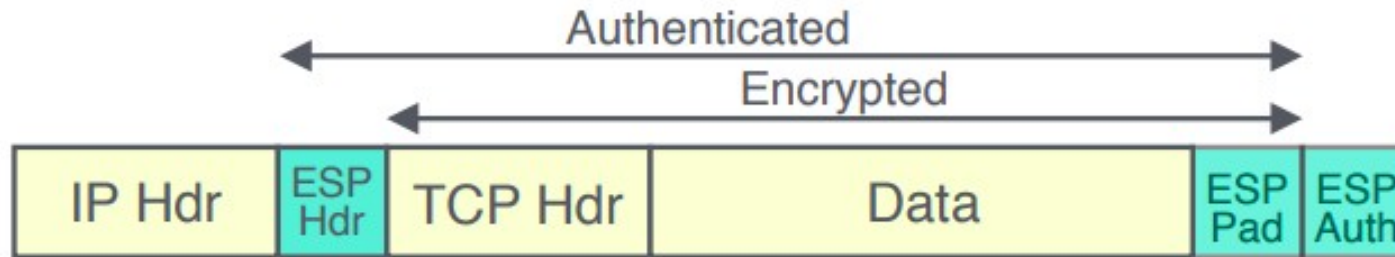
Tunnel Mode



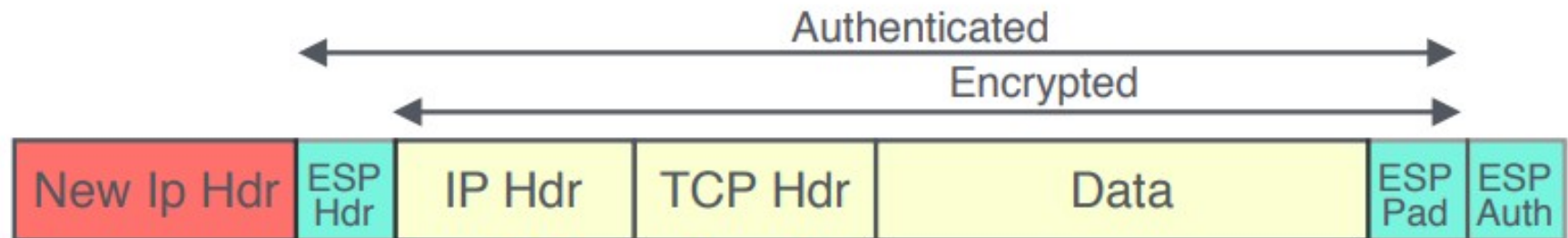
IP Security Modes



a) Original packet



b) Transport mode



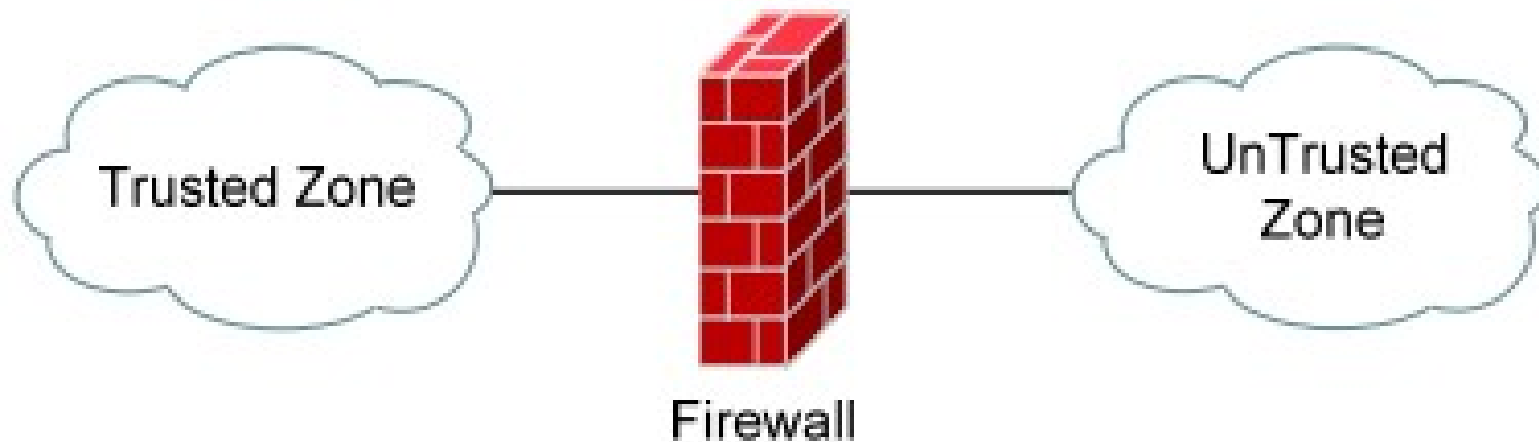
c) Tunnel mode

Firewall

- A firewall is defined as any device (or software) used to filter or control the flow of traffic between internal network and internet.
- Internal network is trusted zone and internet is untrusted zones.
- Most firewalls will permit traffic from the trusted zone to the untrusted zone by default.
- However, traffic from the untrusted zone to the trusted zone must be explicitly permitted using security policies.
- Firewalls are implemented at boundary.

Firewall

- Traffic that is not explicitly permitted from the untrusted to trusted zone will be implicitly denied (by default on most firewall systems)



Characteristics of Firewall

- All traffic from inside to outside, and vice versa, must pass through the firewall.
- Only authorized traffic, as defined by the local security policy, will be allowed to pass.
- The firewall itself designed and maintained in such a way that it is hard to compromise.
- Dedicated firewall device is better than the software firewall installed in a PC.

Capabilities of Firewall

- A firewall defines a single choke point that keeps unauthorized users out of the protected network.
- A firewall provides a location for monitoring security-related events.
- Audits and alarms can be implemented on the firewall system
- A firewall is a convenient platform for several Internet functions that are not security related.
- A firewall can serve as the platform for IPsec.

Limitations of Firewall

- cannot protect against attacks bypassing firewall
- may not protect fully against internal threats
- improperly secured wireless LAN can be accessed from outside the organization
- laptop, PDA, or portable storage device may be infected outside the corporate network then used internally

Types of Firewall

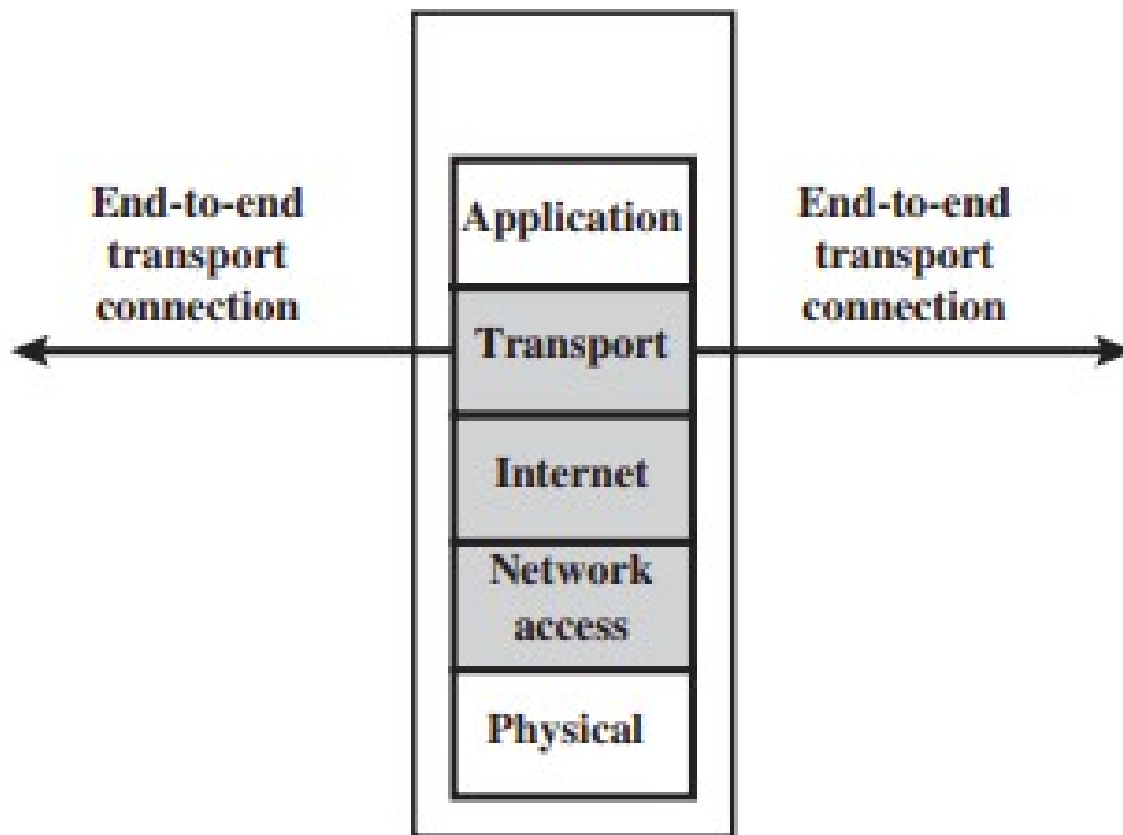
- Packet Filtering firewall
- Stateful Inspection firewall
- Application level firewall
- Circuit level proxy firewall

Types of Firewall

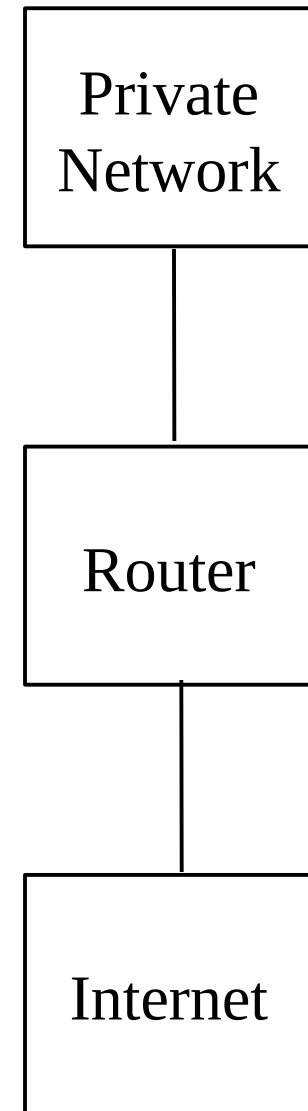
- **Packet Filtering firewall**
- A packet filtering firewall applies a set of rules to each incoming and outgoing IP packet based on IP addresses and port numbers.
- So, it uses information in TCP header and IP header of the packet.
- For e.g. no one is allowed to do telnet on my machine.
- So, packet filtering can be done using router by implementing access list.

Types of Firewall

- **Packet Filtering firewall**



(b) Packet filtering firewall



Types of Firewall

policy	Firewall Setting
No outside web access	Drop all outgoing packets to any IP address, port 80.
No incoming TCP connections, except those for organization's public Web server only.	Drop all incoming TCP SYN packets to any IP except 130.207.244.203, port 80.
Prevent audio-video traffic from eating up the available bandwidth.	Drop all incoming UDP packets except DNS packets.
Prevent your network from being tracerouted	Drop all ICMP packets with expired TTL

Types of Firewall

- **Packet Filtering firewall**

action	source address	dest address	protocol	source port	dest port	flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	—
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	—
deny	all	all	all	all	all	all

Types of Firewall

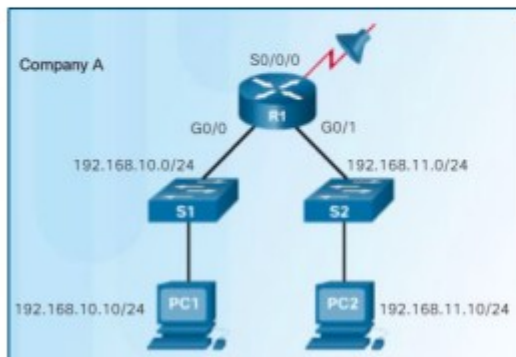
- **Packet Filtering firewall**
- The packet filter is typically set up as a list of rules based on matches to fields in the IP or TCP header.
- If there is a match to one of the rules, that rule is invoked
- If there is no match to any rule, then a default action is taken.

Types of Firewall

- **Packet Filtering firewall**
- Two default rules are
- discard - prohibit unless expressly permitted
- forward - permit unless expressly prohibited

Standard IPv4 ACL Implementation

- An IPv4 ACL is linked to an interface using the following interface configuration mode command:
 - **ip access-group** {ACL-# | access-list-name} {in | out}



```
R1(config)# access-list 1 permit 192.168.10.0 0.0.0.255
R1(config)# interface s0/0/0
R1(config-if)# ip access-group 1 out
```


Types of Firewall

- **Packet Filtering firewall**

```
!--- This command is used to permit IP traffic from 10.1.1.0  
!--- network to 172.16.1.0 network. All packets with a source  
!--- address not in this range will be rejected.
```

```
access-list 101 permit ip 10.1.1.0 0.0.0.255 172.16.1.0 0.0.0.255
```

```
!--- This command is used to permit IP traffic from 10.1.1.0  
!--- network to 172.16.1.0 network. All packets with a source  
!--- address not in this range will be rejected.
```

```
access-list 102 permit ip 10.1.1.0 0.0.0.255 172.16.1.0 0.0.0.255  
access-list 102 deny ip any any
```

Types of Firewall

- **Packet Filtering firewall**

- Extended ACLs can filter on protocol and port number.
- An application can be specified by configuring either:

- The port number

```
access-list 114 permit tcp 192.168.20.0 0.0.0.255 any eq 23
access-list 114 permit tcp 192.168.20.0 0.0.0.255 any eq 21
access-list 114 permit tcp 192.168.20.0 0.0.0.255 any eq 20
```

- The name of a well-known port.

```
access-list 114 permit tcp 192.168.20.0 0.0.0.255 any eq telnet
access-list 114 permit tcp 192.168.20.0 0.0.0.255 any eq ftp
access-list 114 permit tcp 192.168.20.0 0.0.0.255 any eq ftp-data
```

- Note:
 - Use the question mark (?) to see available well-known port names.
 - E.g., `access-list 101 permit tcp any any eq ?`

Types of Firewall

- **Packet Level firewall**

```
!--- This command is used to permit Telnet traffic  
!--- from machine 10.1.1.2 to machine 172.16.1.1.
```

```
access-list 101 permit tcp host 10.1.1.2 host 172.16.1.1 eq telnet
```

```
!--- This command is used to permit tcp traffic from  
!--- 10.1.1.2 host machine to 172.16.1.1 host machine.
```

```
access-list 101 permit tcp host 10.1.1.2 host 172.16.1.1
```

```
!--- This command is used to permit udp traffic from  
!--- 10.1.1.2 host machine to 172.16.1.1 host machine.
```

```
access-list 101 permit udp host 10.1.1.2 host 172.16.1.1
```

Types of Firewall

- **Packet Filtering firewall**
- **Advantages** are
 - Simple and fast
 - Transparent to users as users must not know about the packet filtering firewall.
- **Disadvantages:**
 - Difficult to set up packet filters as rules may become large.
 - Lack of authentication no cryptography techniques are used. [Topic 1](#)

Types of Firewall

- **Stateful Inspection firewall** maintains a table of active TCP connections
- It uses this knowledge for filtering decisions.
- Recall the packet filtering access list that allow the packet with ACK=1 and port=80 to pass through the firewall from internet.
- Attacker can crash the system by sending large malformed packets with ACK=1 and port=80
- Such packet will be allowed by firewall if we have access list as mentioned before.

Types of Firewall

- **Stateful Inspection firewall** prevents such attack by checking the connection table.
- If connection has been established, only then firewall will allow such packets.
- Otherwise it will drop such packets.

Types of Firewall

- **Stateful Inspection firewall**

action	source address	dest address	protocol	source port	dest port	flag bit	check conxion
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any	
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK	X
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	—	
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	—	X
deny	all	all	all	all	all	all	

Table 8.8 ♦ Access control list for stateful filter

Types of Firewall

- **Stateful Inspection firewall**

source address	dest address	source port	dest port
222.22.1.7	37.96.87.123	12699	80
222.22.93.2	199.1.205.23	37654	80
222.22.65.143	203.77.240.43	48712	80

Table 8.7 ♦ Connection table for stateful filter

Types of Firewall

- **Application Level firewall**
- Packet filtering allows filters packets on the basis of the contents of IP and TCP/UDP headers, including IP addresses, port numbers, and acknowledgment bits.
- But what if firewall needs to filter a service to a restricted set of internal users.
- Such tasks are beyond the capabilities of traditional and stateful filters.

Types of Firewall

- **Application Level firewall**
- Indeed, information about the identity of the internal users is application-layer data and is not included in the IP/TCP/UDP headers.
- For this type of filter, packet firewalls must combine with application gateways.
- Application gateways look beyond the IP/TCP/UDP headers and make policy decisions based on application data.
- An application gateway is an application-specific server.

Types of Firewall

- **Application Level firewall**
- All application data (inbound and outbound) must pass through application level gateway.
- Multiple application gateways can run on the same host, but each gateway is a separate server with its own processes.
- Some of application are telnet, ftp, icmp, smtp.

Types of Firewall

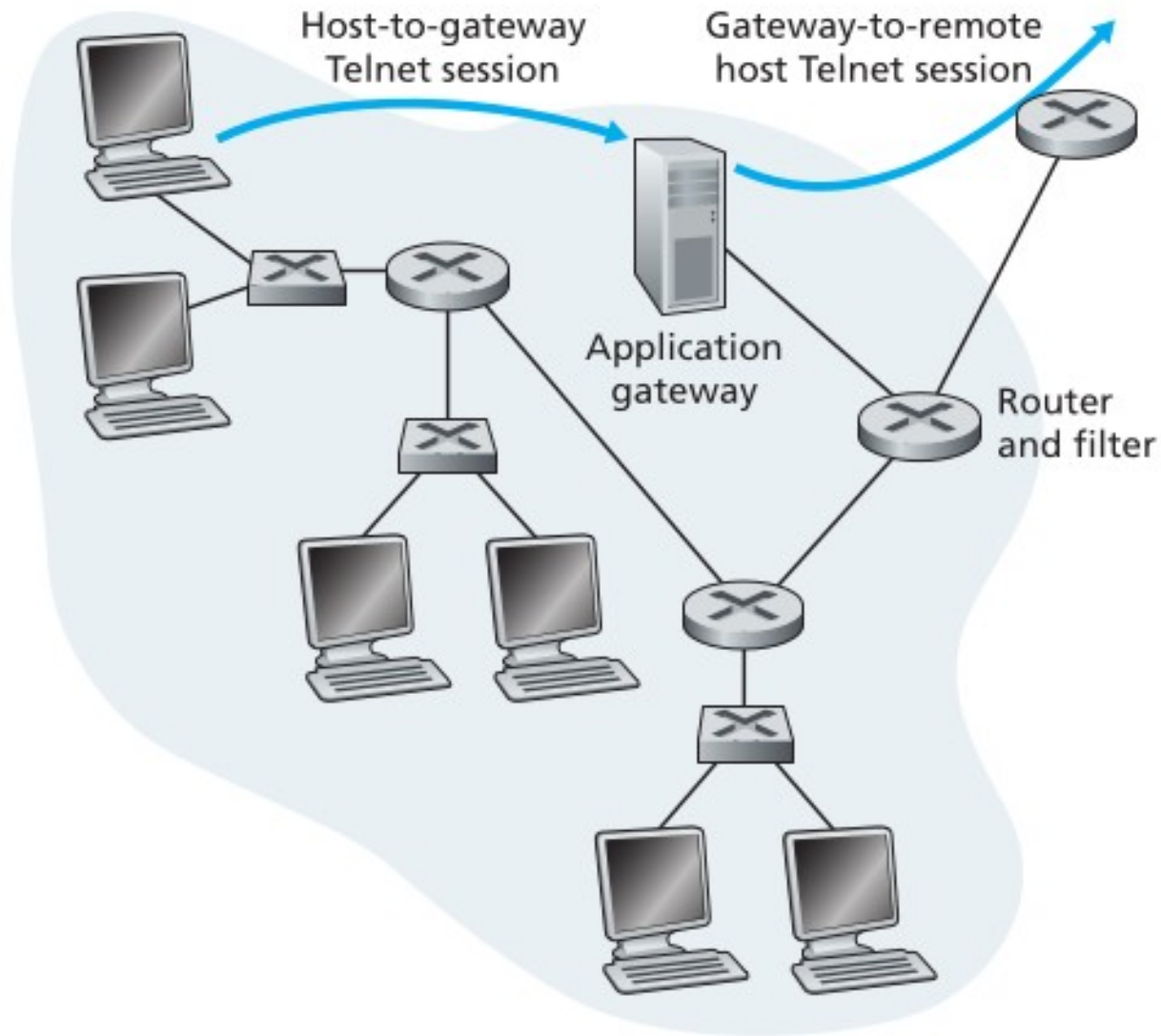


Figure 8.34 ♦ Firewall consisting of an application gateway and a filter

Types of Firewall

- **Application Level firewall**
- To get some insight into application gateways, let's design a firewall that allows only a restricted set of internal users to Telnet outside and prevents all external clients from Telneting inside.
- Such a policy can be accomplished by implementing a combination of a packet filter (in a router) and a Telnet application gateway, as shown in Figure above.
- The router's filter is configured to block all Telnet connections except those that originate from the IP address of the application gateway.

Types of Firewall

- **Application Level firewall**
- All the outbound Telnet connections are forced to pass through the application gateway.
- Consider now an internal user who wants to Telnet to the outside world.
- The user must first set up a Telnet session with the application gateway.
- An application running in the gateway, which listens for incoming Telnet sessions, prompts the user for a user ID and password.

Types of Firewall

- **Application Level firewall**
- When the user supplies this information, the application gateway checks to see if the user has permission to Telnet to the outside world.
- If not, the Telnet connection from the internal user to the gateway is terminated by the gateway.
- If the user has permission, then the gateway prompts the user for the host name of the external host to which the user wants to connect,

Types of Firewall

- **Application Level firewall**
- Then, it sets up a Telnet session between the gateway and the external host
- It relays all data arriving from the user to the external host , and all data arriving from external host to the user.

Types of Firewall

- **Application Level firewall**
- **Advantages:**
- Application-level gateways tend to be more secure than packet filters.
- The application-level gateway need only scrutinize a few allowable applications.
- Proxy server maintains a log file for each request.
- So, its easy audit all incoming traffic at the application level and check who is doing what.

Types of Firewall

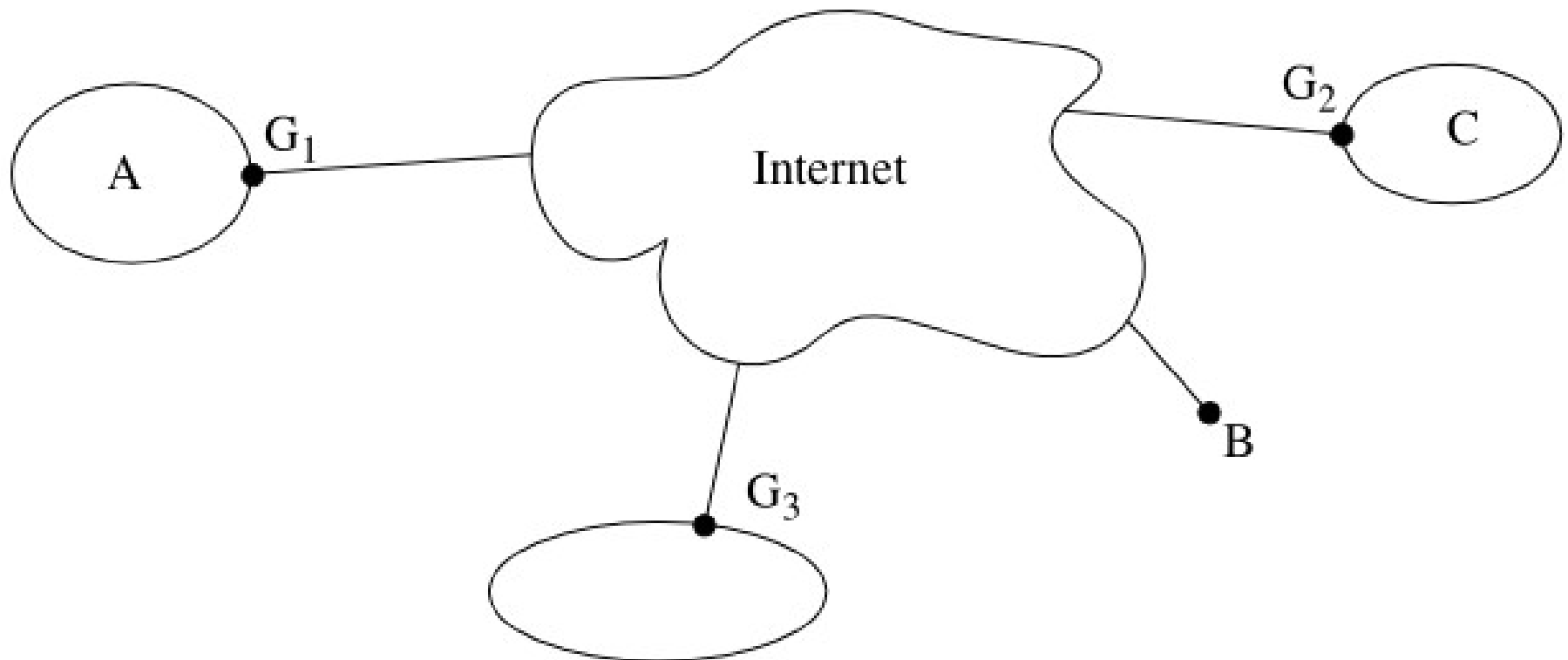
- **Application Level firewall**
- **Disadvantages:**
- A different application gateway is needed for each application.
- There is a performance penalty since all data will be replayed via the gateway.
- This becomes a concern when multiple users are using the same gateway.

Types of Firewall

- **Circuit Level firewall**
- Circuit level firewall achieves security by establishing vpn between two gateway routers.
- The gateway routers are configured with security information.
- There is no end to end TCP connections.
- Instead router will relay one TCP connection with another.
- Typically used when users are trusted.

Types of Firewall

- **Circuit Level firewall**



Types of Firewall

- **Circuit Level firewall**
- Here, gateway router G1, G2, and G3 are configured with security information.
- When A sends a packet to C, A will launch it with an IP header that has source=A, destination=C.
- When G1 sends it across the tunnel, it puts it into another envelope, i.e., it adds an additional IP header, treating the inner header as data.

Types of Firewall

- **Circuit Level firewall**
- The outer IP header will contain source=G1 and destination=G2. And all the contents (including the inner IP header) will be encrypted and integrity protected, so it is safe to traverse the Internet.